

Prénom NOM : Youenn LE JEUNE

Maître de stage dans l'établissement d'accueil : Erwann ROUSSY, Savoir-faire Linux

Adresse de l'établissement d'accueil : 74A Rue de Paris, 35000 Rennes

Titre du stage : Maintien en condition de sécurité de LF Energy SEAPATH

Résumé de la mission du stage : *(contexte et travail à réaliser)*

SEAPATH est un hyperviseur temps-réel à haute disponibilité. De manière résumée, il s'agit d'une distribution Linux personnalisée avec des caractéristiques très particulières :

- La distribution dispose de toutes les fonctionnalités pour faire tourner des Machines Virtuelles (VM).
- Le noyau Linux intégré a les fonctionnalités Temps Réel (RT) activées.
- Il est possible de créer un cluster de machines avec SEAPATH pour que les VM tournent en continu sans interruption de service (la "haute disponibilité").

Ces fonctionnalités rendent SEAPATH très utile pour les distributeurs d'énergie tels que RTE ou Enedis : en faisant tourner des VMs avec des logiciels de monitoring du réseau électrique, des coupes-circuits, etc. sur un cluster SEAPATH, ils s'assurent que leurs systèmes répondront avec une latence très faible (temps réel) et qu'il n'y aura pas d'interruption (haute disponibilité).

SEAPATH est un projet open-source de la Linux Foundation pour l'Énergie et Savoir-faire Linux (SFL) est un des principaux contributeurs. Un des projets actuels de SFL pour SEAPATH est de mettre en place un système automatisé de détection des CVEs (vulnérabilités) sur le système, d'analyser les CVEs remontées et de rendre ces analyses publiques.

Durant ce premier mois de stage, j'ai suivi des formations sur SEAPATH et sur son système de build, Yocto. J'ai pris en main le logiciel VulnScout qui est un outil d'évaluation de vulnérabilités open-source maintenu par SFL. J'ai étudié et mis en places plusieurs méthodes de détections de CVEs dans Yocto : un outil intégré, des scripts pour améliorer les résultats et un outil d'analyse via SBOM (liste de tous les composants logiciels du système). J'ai fait un rapport détaillé sur ces différentes méthodes avec statistiques et analyse des différences, que je publierai ensuite en billet de blog.

J'ai également dû analyser quelques CVEs qui étaient remontées par ces systèmes pour voir si elles étaient applicables ou non, en regardant les versions applicables dans différentes bases de données (NIST NVD, CVE™ Program, Linux Kernel vulns), les sources utilisées lors de la compilation, etc.

J'ai fait plusieurs contributions aux outils que j'ai utilisé durant ce premier mois : corrections de bugs dans VulnScout, rapporter des bugs à sbom-cve-check, remonter des exclusions de CVEs aux mailing lists du projet Yocto.

Enfin, j'ai commencé à créer une pipeline de CI/CD pour automatiser la détection de CVEs en utilisant les outils étudiés précédemment.

Domaines d'application : *(traitement d'images, protocoles réseaux, télévision numérique, etc.)*

Distribution d'électricité

Environnements : *(langages, systèmes, etc.)*

Yocto (Bitbake), Python, GitHub Actions, Ansible